Studio Nx

백엔드 159 — /auth/refresh 재설정 이전 로그인 거부

2026-10-14

백엔드 159 — `/auth/refresh`에 재설정 이전 로그인 거부 연결

항목	내용
파일	`studionx/backend/app/api/v1/auth.py`의 `refresh()`
작업	P1-28 비밀번호 찾기 (FR-118): 열 번째 함수 (기존 함수에 검사 하나를 더함)
작성	Claude (AI), 2026-10-15, 사용자 검토
이전	158 get_current_user()
시험	`tests/test_auth_routes.py` 4개 추가 (파일 전체 47개)
다음	라우터: 재설정 요청과 새 비밀번호 API 두 개를 `/api/v1/auth`에 연결

1. 하는 일

`/auth/refresh`(액세스 토큰 재발급)에서, 비밀번호를 재설정하기 **전에** 발급된 리프레시 토큰을 **401로 거부하고 쿠키도 지웁니다.** 158번과 함께 이전 기기가 로그인을 이어 가는 두 길(액세스 토큰, 재발급)이 모두 닫힙니다.

상황	결과
재설정한 적 없는 계정	전과 같이 200 (쿠키는 건드리지 않음)
재설정 **이전**에 발급된 리프레시 토큰	401 "Please sign in again." + 쿠키 삭제
재설정 **이후**(같은 초 포함)에 새로 로그인한 토큰	200

2. 바뀐 코드

```
user_id, issued_at = decode_token_with_iat(refresh_token, "refresh")   # decode_refresh_token에서 교체
user = auth_service.get_active_user(db, user_id)
if issued_before_password_change(issued_at, user.password_changed_at):   # 새로 더한 검사
    stale = error_json(401, ErrorCode.UNAUTHORIZED, "Please sign in again.")
    clear_refresh_cookie(stale)
    return stale
return TokenResponse(...)
```

3. 왜 이렇게

선택	이유
`AppError`를 던지지 않고 401 응답을 직접 돌려줌	`AppError`를 던지면 예외 처리기가 **새 응답**을 만들어서, 앞서 쿠키 삭제를 적어 둔 헤더가 버려집니다. 쿠키를 지우려면 응답 객체에 직접 적어서 돌려줘야 합니다(시험으로 확인: 던지는 방식으로 바꾸면 쿠키 삭제 시험이 실패)
응답 모양은 `error_json`으로 같게	다른 401과 같은 JSON(`code`, `message`, `details`)이라 화면(`api.js`)의 처리가 그대로 동작합니다
쿠키를 함께 지움	이미 무효가 된 토큰을 브라우저가 `/auth` 아래 요청마다 계속 보내는 것을 막습니다. 지운 뒤에는 "쿠키 없음"(정상 흐름의 401)이 됩니다
같은 문구 "Please sign in again."	만료나 위조된 토큰과 구분되지 않아서 응답으로 "비밀번호가 바뀌었다"를 알아낼 수 없습니다

선택	이유
회원 상태 검사(`get_active_user`) 뒤에 둠	탈퇴, 정지 계정은 `password_changed_at`을 읽기 전에 거부됩니다

4. 시험 (4개 추가, 파일 전체 47개 통과, 실제 앱과 실제 MySQL)

확인	결과
로그인 뒤 재설정하면 재발급이 401, 본문이 다른 401과 같고, `Set-Cookie`로 쿠키가 지워짐(`Max-Age=0`, 같은 경로, `HttpOnly`)	✓
쿠키가 지워진 뒤의 요청은 "쿠키 없음"(정상 흐름의 401, 문구 "Please sign in.")	✓
재설정 직후(같은 초일 수 있음) 새로 로그인하면 재발급이 200	✓
재설정한 적 없는 계정의 재발급은 전과 같음(200, `Set-Cookie` 없음)	✓

시험을 확인하는 시험. 일부러 틀리게 바꿔 시험이 잡는지 보았습니다.

바꾼 것	결과
재설정 검사 제거	2개 실패
쿠키 삭제 제거	2개 실패
`iat` 대신 `None`을 넘김	1개 실패
`AppError`를 던지는 방식으로 되돌림(쿠키 삭제 유실)	2개 실패
리프레시 토큰을 `"access"` 종류로 해독	8개 실패

기존 `refresh` 시험(재발급 성공, 쿠키 없음, 엉터리 토큰, 탈퇴 뒤, 로그아웃 뒤)은 모두 그대로 통과합니다.

전체 pytest 785개 통과, `ruff` 통과.

5. 이제 닫힌 것

경로	이전 기기의 로그인	닫은 함수
액세스 토큰(30분)	재설정 뒤 401	158
리프레시 토큰(3일)으로 재발급	재설정 뒤 401 + 쿠키 삭제	159

이전 기기는 재설정 뒤 최대 몇 분 안에(다음 요청에서) 로그인 화면으로 돌아갑니다. 새 비밀번호로 다시 로그인한 기기는 영향이 없습니다.

6. 남은 일

- 비밀번호 **변경**(FR-107, 로그인한 사용자가 현재 비밀번호를 알고 바꾸는 경우)에는 이 검사를 적용하지 않았습니다. 그 기능은 `password_changed_at`을 기록하지 않아서 다른 기기가 로그아웃되지 않습니다(`user_service.change_password`의 기존 결정: "다른 기기 로그아웃은 하지 않음"). 같은 장치를 쓰고 싶으시면 별도로 정하겠습니다.